

Improved Cyber Defense Modeling Framework for Modeling and Simulating the Lifecycle of Cyber Defense Activities

Asim Rai

Abstract

It is difficult to assess the business impact of a cyberattack and implement appropriate strategies or policies to enhance cyber resilience and counter future attacks. Penetration testing, which is currently gaining popularity, has been employed to assess cyber defense levels in actual operating environments. However, it is expensive and time-consuming and only reveals the current state of a problem without providing insights into potentially better alternative strategies. To overcome these limitations, cybersecurity modeling and simulation (M&S) research, which includes the crucial component of cyber-defense modeling, is being actively conducted. Most cyber defense modeling approaches only model defenses as a response to cyberattacks, neglecting to consider the complexities in the actual cyber defense activities of organizations. Consequently, the intended aim to evaluate and enhance cyber defense capabilities through analysis cannot be met. In this study, we present a cyber defense process model that models the entire lifecycle of cyber defense activities as the following five phases: prevention, monitoring and detection, initial response, attack analysis, and recovery response. This model not only accounts for defense steps that had been neglected in previous studies but also offers improvements to previously introduced defense steps. Additionally, we present a framework for applying initial and recovery response models by progressively integrating a unit response behavior model to counter cyberattacks. The applicability of the proposed model was verified by using a constructed prototype. The results of this study can be applied to developing an M&S-based experimental environment for assessing the sustainability of missions/businesses that have faced cyberattacks.

1. Introduction

With the increased complexity and interconnectedness of society, more functions and data are being managed by personalized, privacy-rich devices such as smartphones and personal computers. Consequently, cyberattacks targeting these devices pose serious problems for individuals and businesses in modern society. These problems are comparable to those faced by the military in its operational environment [1], [2]. However, unlike the private sector, the defense The associate editor coordinating the review of this manuscript and approving it for publication was Rupak Kharel . sector attempts to avoid such vulnerabilities in weapon systems by treating isolated networks and distinct system environments as physically separate from the Internet. In the defense sectors of most nations, cyberattacks have rarely disrupted or disabled military operations, making it difficult for the military to envision the impact and

repercussions of cyberattacks on operational missions. This makes it challenging to analyze potential problems from these attacks and adopt appropriate countermeasures against them. There are numerous strategies for mitigating cyberattacks. One approach is to utilize a cybersecurity framework (CSF) [3], which provides the strategic perspective VOLUME 11, 2023 2023 The Authors. This work is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 License. For more information, see <https://creativecommons.org/licenses/by-nc-nd/4.0/> 114187 D. Kim et al.: Improved Cyber Defense Modeling Framework for Modeling and Simulating the Lifecycle and technical components essential to constructing an organization's comprehensive cybersecurity infrastructure. It is accompanied by a cybersecurity maturity model (CMM) [4] that assesses and categorizes these components in order to prioritize informed decision-making. Another approach entails conducting a thorough technical analysis of potential

attack vectors within the organization's current security framework. This analysis entails evaluating the mission/business impact of potential attack scenarios and incorporating tactical enhancements to prepare for cyberattacks. This work focuses on the second approach, which can be approached in two different methods. The first method, the penetration test, is conducted by numerous businesses on their actual network infrastructure to identify vulnerabilities and attack-susceptible surfaces and select more effective defensive systems. Even in the military sector, divisions frequently conduct penetration tests to share valuable information regarding newly learned lessons and potential ideas for improvements [5]. However, applying penetration testing to large-scale networks and systems is expensive in terms of cost, time, and personnel requirements, and the cost of multiple perspectives increases proportionally when testing is applied to a variety of attack scenarios. Therefore, penetration testing cannot be used to develop policies or procedures for cyber defense operations. The second method involves conducting cybersecurity modeling and simulation (M&S) experiments [6], [7], [8], [9], [10], [11]. Although the fidelity of these experimental results may be lower than those obtained through penetration testing in a real environment, establishing the environment for these experiments is significantly more cost-, effort-, and time-efficient. Consequently, sufficient experimentation with various scenarios can provide the data required to determine the tactics/policies employed by an organization and the response it provides in the event of a cyberattack to maintain its mission or business continuity [10]. To address the fidelity of M&S results, research has also been conducted on developing a constructive-based M&S environment that is interoperable with live-virtual environments [12]. Numerous component technologies are necessary for developing proper M&S approaches for cybersecurity. Unlike cyberattack simulation technologies, cyber defense simulation technologies have not been extensively researched [13], [14]. Most organizations that implement cybersecurity M&S have robust cyberattack response teams and processes and follow government-mandated cyber incident response guidelines [6], [12], [15], [16]. However, current cyber defense modeling studies have not experimentally verified such approaches. This is because many cyber defense modeling studies [17] have been conducted as either ancillary studies aiming to verify the performance of cyberattack modeling instead of focusing on the entire defense activities of an organization or fragmented studies that only focus on individual defense devices. To address this issue, we propose a cyber defense process model framework

comprising five steps, namely prevention, monitoring and detection, initial response, attack analysis, and recovery response, based on an analysis of cyber incident response guidelines implemented by major advanced nations. This was done to implement the cyber defense activities in cybersecurity M&S as a complete cycle. Additionally, we defined the functions, procedures, and information flows for each step of the model. The first step in the model, the prevention step, involves modeling the function of security equipment and security software in a manner consistent with those of previous studies [9], [15], [17]. The next step, the monitoring and detection step, models the monitoring function of a security operation center (SOC) and the attack detection function. Regarding the response step, depending on the amount of information and the purpose of the response, it is modeled into the initial response step, which aims to avoid the spread of attacks, and the recovery response step, which aims to eliminate attacks and restore damaged or lost functions. An attack analysis model is added between the two models to model the time-consuming process of determining the information related to a cyberattack. The cyber defense process model and its detailed steps can be used to conduct simulations that include the general procedures and functions specified under cyber incident response guidelines and reflect various organizational policies, structures, and informationsharing systems. The performance of the proposed framework was confirmed using experiments with an implemented prototype. Additionally, we used the prototype to assess the impact of confidentiality and availability on the effectiveness of various defense policies against cyberattacks. The results of this study can be used to determine the effectiveness of the current cyber-defense structure, policies, and processes of an organization in protecting mission/business-critical systems from various cyberattacks. Additionally, they can be used to identify measures to enhance the efficacy of existing cyber defense measures and provide a compelling rationale for prioritizing them. In the future, these results can be applied to an experimental environment to assess the impacts of cyberattacks on different missions/businesses. The rest of this paper is organized as follows. Section II introduces major agency guidelines and related research on cyber defense modeling, and Section III describes the proposed cyber defense process model framework and comprehensive defense model. Then, Section IV describes the network and cyberattack considered in our experiments with the prototype, followed by the results and analysis of the experiments conducted with seven different configurations. Finally, Section V concludes the paper.

2. RELATED WORKS A. CYBERSECURITY STANDARDS

2.1 CYBERSECURITY FRAMEWORK

The Cybersecurity Framework (CSF) [3] is a standard framework established by the U.S. National Institute of Standards and Technology (NIST) to provide a full-cycle 114188 VOLUME 11, 2023 D. Kim et al.: Improved Cyber Defense Modeling Framework for Modeling and Simulating the Lifecycle strategic direction and technical practices for proactively preventing cyberattacks. The five functions of “Identify,” “Protect,” “Detect,” “Respond,” and “Recover” defined in the Framework Core of the CSF are organized according to the life cycle stages for constructing a cybersecurity system, and the technical practices to be performed in each function are classified by category and subcategory. The CSF Implementation Tiers are intended to provide the context and methodology for implementing processes to address cybersecurity threats, as well as the level at which these processes are performed, ranging from Partial (Tier 1) to Adaptive (Tier 4). A Cybersecurity Maturity Model (CMM) is a method for assessing an organization’s implementation and operations of cybersecurity practices and identifying priority areas for improvement from a strategic perspective. The Cybersecurity Capacity Maturity Model (C2M2) [4], devised by the U.S. Department of Energy, is a model of the CMMs that examines and assesses over 300 action items in 10 domain areas and diagnoses them at three levels. In addition to CFS, the mapping relationship between CSF and C2M2 can be used to evaluate a CSF-based security environment. The focus of this study is to validate, through engagement-level simulations, that cyber defense environments, systems, and processes developed using methodologies such as CSF and CMM function at the desired level against specific attacks. In comparison to the Framework Core of the CSF, the technical practices of Detect, Respond, and Recover can be tested to ensure they function in a timely manner during a specific attack. If they do not, it can analyze the reasons for their failure, including the temporal element.

2) CYBER INCIDENT RESPONSE FRAMEWORKS

Numerous nations have provided guidelines for both public and private sectors on cyberattack preparation, including the existing organizations and processes that can respond to cyber breaches [18], [19], [20], [21]. This section describes the steps in establishing a cyber-defense process and details each step. The working of numerous organizations with cyber defense manuals or SOC’s are based on these guidelines. Figure 1 summarizes the cyberattack response frameworks adopted by four

major organizations. The basic steps include preparing for a potential attack, recognizing a cyberattack after detection, containing the spread of the attack and FIGURE 1. Computer security incidence response frameworks of major agencies for cyber security [18], [19], [20], [21]. eradicating it, and restoring the system. Additionally, the organization employs postmortem analysis to implement measures for improving security. Generally, the preparation step involves setting up the necessary components required to respond to an incident, such as establishing an emergency communication system, preparing the tools (both hardware and software) required for incident analysis, and preventing potential incidents by ensuring the proper security of systems, networks, and applications. Each organization is similar in how it performs the following steps: detecting cyberattacks, understanding the context of a breach, preventing the spread of an attack, and undertaking attack analysis. However, each has distinct guidelines for recognizing and recovering from a breach. After the complete eradication of a cyberattack, the process of system normalization is initiated. After an organization has recovered from a breach, it reflects on the incident and undertakes preparations to create a more robust security system.

2.2 CYBER DEFENSE MODELING STUDIES

Kotenko et al. [7] proposed a framework for conducting M&S for cyberattack and defense, in which three types of agents operate in a distributed and cooperative manner: cyberattack, cyber defense, and user. They implemented it using a combination of discrete-simulation tools and packet-level simulators and presented the results of simulation experiments involving distributed denial of service attacks, which are significant issues. Defense agents, which are the primary focus of this research, are further classified according to their functions as follows: information processing (sampler), attack detection (detector), filtering and balancing (filter), and traceback and investigation (investigator). The sampler is a defense agent that learns data for hop-count filtering (HCF), source Internet Protocol (IP) address monitoring (SIPM), and bits per second (BPS) prior to the actual simulation. The agent responsible for attack detection is the detector, which detects attacks based on the threshold value derived from the sampler. When messages are detected by the detector, the filter blocks them. The IP address of the attack source is deduced from the malicious packets and further traffic from that address is blocked. Ten et al. [8] proposed and experimentally validated a real-time monitoring, anomaly detection, impact analysis, and mitigation strategy (RAIM)-based supervisory control and data

acquisition (SCADA) security framework and evaluation method for power systems. Implementing the RAIM framework can effectively mitigate the impact of a cyberattack on a power system. Methods for modeling and assessing the impact of cyberattacks have also been presented for this purpose. The first step in RAIM involves the real-time monitoring of information and power systems, which is followed by anomaly detection step, wherein the spatial, temporal, or spatio-temporal correlations between observed events are analyzed to detect cyberattacks and VOLUME 11, 2023 114189 D. Kim et al.: Improved Cyber Defense Modeling Framework for Modeling and Simulating the Lifecycle generate possible cyberattack scenarios. Then, in the impact analysis step, the vulnerability of information and power systems to cyberattacks is evaluated based on the behavior of the perpetrator and possible attack scenarios, and the probability of capacity loss in the power system due to this vulnerability is evaluated. Finally, in the mitigation strategy, appropriate control actions are taken to prevent and mitigate risks based on the progression of the attack and risk situation in each of the three stages (attack attempt, ongoing attack, and ongoing attack targeting the power system). Cho et al. [9] proposed a method for integrating three defense methods, namely the intrusion detection system (IDS), deception, and moving target defense, using an integrated modeling approach. The proposed method was implemented using stochastic Petri nets, and the performance of the three defense methods in combination was experimentally validated using evaluation metrics, such as system lifetime, accumulated defense cost, attack success probability, and accumulated attack cost. Rajivan et al. [22] proposed a method for simulating a cyber defense team of analysts with the aim of comprehending team performance from both a macro perspective, which involves team effectiveness, and a micro perspective, which involves the collaboration between the analysts in a team. They thoroughly outlined the steps in modeling the number of analysts in a team and the manner wherein they should collaborate to effectively manage many security alerts. They presented a comprehensive approach to human modeling, which included learning strategies for individual analysts to attain greater rewards and collaboration strategies for teams to enhance performance. Overall, the model for cyber defense activities is limited to managing security notifications, resulting in the simulations being limited to tasks such as selecting the analysts for a team and determining their cooperative strategy for handling more alerts. Analyzing Mission Impacts of Cyber Actions (AMICA) [10] is a multi-layered M&S approach for quantitatively assessing the operational

mission impact of a cyberattack on a specific mission, which includes operational (kinetic) missions, mission-related computing infrastructure, cyberattacker tactics, techniques, and procedures (TTPs), and cyber defender TTPs. The working of a cyber defense model includes the following steps: the triage step, which identifies and classifies security alerts, including attack detection, which generates security alerts; the forensics step, which analyzes the target of security alerts; and the reboot, restore, and rebuild steps, which are performed according to the recovery actions required after the previous step. Excepting the activities in the triage step, those in the forensics and recovery activity steps are simulated in terms of time, spanning from 5 min for straightforward actions, such as rebooting, to 6 h for identifying infected hosts using derived signatures. The response guidelines for cyberattacks can be analyzed based on the preceding information as follows. FIGURE 2. Generalized cyber defense modeling architecture in existing research. (i) In the preparation step, attempts are made to prevent as many cyberattacks as possible before they are even recognized. (ii) In the operational process, attacks are detected rapidly and accurately. (iii) Following cyberattack detection, an initial response to mitigate the damage and contain its spread is implemented. (iv) Subsequently, an attack analysis is conducted to understand the precise circumstances and details of the attack. (v) Efforts are continued to completely eradicate cyberattacks in the organization and restore the normal operation of mission/business-critical systems based on the information obtained, such as the tools used in the attack, the method of the attack, and the scope of the attack. (vi) Once the systems are stabilized, the steps in cyber defense are iterated, and preparations are started for dealing with new attacks and detecting any attempted attacks. In contrast, generalized architecture of previous cyber defense modeling studies in cybersecurity M&S primarily included prevention and response models, as depicted in Figure 2, that could not accurately represent practical cyber defense activities [9], [15], [17], [22], [23], [24]. There are parts of the cyber defense process that can have important consequences but are not simulated in previous studies. Examples include how to handle misuse by legitimate users that is ignored by the security control center, and the critical initial response after detection of a cyberattack. Even if there was an investigation or analysis phase [7], [8], [10], it was limited to information output with either only the time delay or no consideration for policy changes, resulting in an environment unsuitable for conducting a variety of defender-related ex

REFERENCES [1] R. Koch and M. Golling, "Weapons systems and cyber security—A

challenging union,” in Proc. 8th Int. Conf. Cyber Conflict (CyCon), May 2016, pp. 191–203. [2] D. L. Bergin, “Cyber-attack and defense simulation framework,” *J. Defense Model. Simul., Appl., Methodol., Technol.*, vol. 12, no. 4, pp. 383–392, Oct. 2015. [3] Cybersecurity Framework (CSF). National Institute of Standards and Technology. Accessed: Sep. 8, 2023. [Online]. Available: <https://www.nist.gov/cyberframework> [4] Cybersecurity Capacity Maturity Model (C2M2). USA Office of Cybersecurity, Energy Security, and Emergency Response. Accessed: Sep. 8, 2023. [Online]. Available: <https://www.energy.gov/c2m2/cybersecurity-capability-maturity-model-c2m2> [5] N. J. Hwang and K. B. Bush, “Operational exercise integration recommendations for DoD cyber ranges,” Lincoln Lab., Lexington, MA, USA, Tech. Rep. 1187, 2015. [6] M. K. Ahn, Y. H. Kim, and J. R. Lee, “Hierarchical multi-stage cyber attack scenario modeling based on G&E model for cyber risk simulation analysis,” *Appl. Sci.*, vol. 10, no. 4, p. 1426, 2020. [7] I. Kottenko, “Multi-agent modelling and simulation of cyber-attacks and cyber-defense for homeland security,” in Proc. 4th IEEE Workshop Intell. Data Acquisition Adv. Comput. Syst., Technol. Appl., Sep. 2007, pp. 614–619. [8] C.-W. Ten, G. Manimaran, and C.-C. Liu, “Cybersecurity for critical infrastructures: Attack and defense modeling,” *IEEE Trans. Syst., Man, Cybern. A, Syst. Humans*, vol. 40, no. 4, pp. 853–865, Jul. 2010. [9] J. H. Cho and N. Ben-Asher, “Cyber defense in breadth: Modeling and analysis of integrated defense systems,” *J. Defense Model. Simul.*, vol. 15, no. 2, pp. 147–160, 2018. [10] S. Noel, J. Ludwig, P. Jain, D. Johnson, R. K. Thomas, J. McFarland, B. King, S. Webster, and B. Tello, “Analyzing mission impacts of cyber actions (AMICA),” in Proc. NATO IST-128 Workshop Cyber Attack Detection, Forensics Attribution Assessment Mission Impact, 2015, pp. 1–16. [11] T. Grafenauer, S. König, S. Rass, and S. Schauer, “A simulation tool

for cascading effects in interdependent critical infrastructures,” in Proc. 13th Int. Conf. Availability, Rel. Secur., 2018, pp. 1–8. [12] D. Lee, D. Kim, M. K. Ahn, W. Jang, and W. Lee, “Cy-through: Toward a cybersecurity simulation for supporting live, virtual, and constructive interoperability,” *IEEE Access*, vol. 9, pp. 10041–10053, 2021. [13] M. R. Stytz and S. B. Banks, “Future challenges for cyber simulation,” *J. Defense Model. Simul., Appl., Methodol., Technol.*, vol. 17, no. 1, pp. 47–49, Jan. 2020. [14] M. Lange, A. Kott, N. Ben-Asher, W. Mees, N. Baykal, C.-M. Vidu, M. Meriardo, M. Malowidzki, and B. Madahar, “Recommendations for model-driven paradigms for integrated approaches to cyber defense,” 2017, arXiv:1703.03306. [15] M. Park, H. Lee, Y. Kim, K. Kim, and D. Shin, “Design and implementation of multi-cyber range for cyber training and testing,” *Appl. Sci.*, vol. 12, no. 24, 2022, Art. no. 12546. [16] ATT&CK. MITRE. Accessed: May 8, 2023. [Online]. Available: <https://attack.mitre.org> [17] P. Nespoli, D. Papamartzivanos, F. Gómez Mármol, and G. Kambourakis, “Optimal countermeasures selection against cyber attacks: A comprehensive survey on reaction frameworks,” *IEEE Commun. Surveys Tuts.*, vol. 20, no. 2, pp. 1361–1396, 2nd Quart., 2018. VOLUME 11, 2023 114199 D. Kim et al.: Improved Cyber Defense Modeling Framework for Modeling and Simulating the Lifecycle [18] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, Special Publication 800-61: Computer Security Incident Handling Guide, 2nd ed., National Institute of Standards and Technology, Gaithersburg, MD, USA, 2012. [19] Guidelines 2010-8, Computer Security Incident Analysis Process Guide, 3rd ed., Korea Internet & Security Agency (KISA), Naju, South Korea, 2010. [20] P. Kral, The Incident Handlers Handbook, SANS Institute, Rockville Pike, MD, USA, 2011. [21] M. Maj, R. Reijers, and D. Stikvoort, Good Practice Guide for Incident Management, European Network

and Information Security Agency (ENISA), Athens, Greece, 2010. [22] P. Rajivan, M. A. Janssen, and N. J. Cooke, “Agent-based model of a cyber security defense analyst team,” in *Proc. Hum. Factors Ergonom. Soc. Annu. Meeting*, vol. 57, no. 1. Los Angeles, CA, USA: SAGE, 2013, pp. 314–318. [23] E. Hemberg, J. R. Zipkin, R. W. Skowrya, N. Wagner, and U.-M. O’Reilly, “Adversarial co-evolution of attack and defense in a segmented computer network environment,” in *Proc. Genetic Evol. Comput. Conf. Companion*, Jul. 2018, pp. 1648–1655. [24] M. Ge, J. H. Cho, B. Ishfaq, and D. S. Kim, “Modeling and analysis of integrated proactive defense mechanisms for Internet of Things,” in *Modeling and Design of Secure Internet of Things*, 2020, pp. 217–247. [25] D. L. Olson and D. Delen, *Advanced Data Mining Techniques*. Cham, Switzerland: Springer, 2008. [26] D3FEND. MITRE. Accessed: May 8, 2023. [Online]. Available: <https://d3fend.mitre.org> [27] (2021). vsTasker. VirtualSim. Accessed: May 8, 2023. [Online]. Available: <https://www.virtualsim.com/products/vstasker> [28] S. Choi, M. Kim, J. Youn, M. Park, S. Lee, and D. Shin, “A study on cyber resilience evaluation method centered on infringement response time,” *J. Defense Secur.*, vol. 4, no. 2, pp. 87–110, 2022.